Прогнозирование компьютерных атак: три практических метода для аналитика

Автор: Григорий Емельянов

специалист по выявлению и оценке угроз КИ и КА

30.09.2026

© Емельянов Григорий Андреевич github.com/emelyagr Все права защищены

Введение

Современный ландшафт киберугроз для российских организаций характеризуется устойчивым ростом числа атак, диверсификацией тактик злоумышленников и расширением целевых отраслей. Промышленный сектор, государственные структуры, финансовые организации, ритейл и телеком традиционно находятся в зоне повышенного риска, при этом противники всё чаще уходят от шумных техник и действуют скрытно и методично. В этих условиях реактивная модель защиты, при которой SOC реагирует на уже состоявшийся инцидент, становится недостаточной. На первый план выходит прогнозирование — способность предвидеть атаку до её реализации. При прогнозировании фокус аналитиков может падать на исследование подготовки ресурсов и инфраструктуры к атакам.

В статье рассмотрены три метода прогнозирования, которые могут быть использованы аналитиком в повседневной практике: мониторинг новых доменных имён, анализ бюллетеней угроз и OSINT-разведка с профилированием группировок. Каждый метод дополняет остальные, формируя комплексную систему упреждающего выявления угроз.

Прогнозирование на основе анализа тайпсквоттинга

Прогнозирование через мониторинг новых доменных имён (Newly Registered Domains, NRD) строится на простом наблюдении: прежде чем атаковать, злоумышленник должен подготовить инфраструктуру (Resource Development). Сейчас фишинговый домен, имитирующий бренд организации, используется не только для формирования поддельных веб-сайтов, но и для вредоносной рассылки. Злоумышленники также регулярно отслеживают освобождающиеся

домены для их закупки. Зачастую доменное имя регистрируется заранее — иногда за дни, иногда за месяцы до первой атаки. Задача аналитика — обнаружить этот домен в окне между его регистрацией и первым контактом с жертвой.

В России эта задача решается как в немногочисленных коммерческих решениях, так и в рамках проекта «Доменный патруль» Координационного центра .RU/.РФ. С проектом работают компетентные организации, включая НКЦКИ и профильные исследовательские центры. Механика выявления такова: программа генерирует перестановки доменов целевых брендов — заменяет символы на визуально схожие, добавляет дефисы, меняет доменные зоны, — после чего автоматизированно проверяет каждую итерацию на предмет существования.

Наличие MX-записи у нового подозрительного домена — это не просто техническая деталь, а прямой сигнал о готовящейся фишинговой рассылке. Детектирование MX-записи используется как индикатор того, что владелец домена намеревается отправлять исходящие письма, от имени этого домена. Иными словами, если свежезарегистрированный домен, лексически схожий с брендом вашей организации, обзавёлся MX-записью — означает, что инфраструктура готовится к рассылке, и у вас есть окно в несколько часов или дней до наступления первых атак.

Исследования показывают, что значительная доля доменов, имитирующих корпоративные бренды, имеет активные MX-записи. Современные фишинговые наборы пошли дальше: инструмент Morphing Meerkat использует MX-записи для динамической подстановки. При заходе жертвы на фишинговую страницу набор запрашивает MX-запись её почтового домена через публичные DNS-резолверы (Cloudflare DoH, Google Public DNS) и на основе этого загружает тот HTML-файл,

который имитирует интерфейс именно её почтового провайдера, с уже предзаполненным адресом электронной почты для правдоподобия.

Практический кейс, из реальной практики аналитика: домен визуально почти не отличался от легитимного — небольшая опечатка, которую легко пропустить, — и инструменты по типу VirusTotal ещё не детектировали его как вредоносный. Однако сконфигурированная MX-запись выдала подготовку инфраструктуры к фишинговой кампании. Это классический опережающий сигнал: традиционные средства защиты, ориентированные на репутацию и сигнатуры, пропускают такой домен, потому что он ещё не «засветился», но контекст — свежая регистрация плюс MX-запись плюс лексическое сходство с брендом — даёт аналитику основания для упреждающей блокировки.

Промышленность отрасль. Rare Werewolf (Librarian Likho, Rezet) регулярно рассылает письма от имени двух-трёх реальных организаций. Для этого она постоянно регистрирует новые доменные имена, визуально и фонетически похожие на легитимные. Письма выглядят не как шаблонный спам, а как начало или продолжение реальной деловой переписки — с корректными подписями, телефонными номерами, упоминанием контрагентов, ссылками на документы. В качестве почтовых адресов отправителей используются недавно зарегистрированные домены, имитирующие ранее скомпрометированную организацию промышленного сектора (дважды: в 2024 и 2026 годах). Похожих доменных имён специалистами выявлено более 20. На данный момент это одна из отличительных особенностей данной группировки. При этом можно отметить и наименование других организаций, фишинговых доменных имён которых выявлено чуть меньше 10.

Государственный сектор. Широко распространена сеть фишинговых ресурсов, маскирующихся под Минобрнауки и «Госуслуги». Классическая схема работает в два этапа: сначала жертву заманивают на сайт с доменом, содержащим слово minobrnauki, где требуют ввести ФИО, телефон, ИНН, СНИЛС или паспортные данные, после чего перенаправляют на второй фишинговый сайт с доменом, содержащим слово gosuslugi, имитирующий интерфейс портала. На втором этапе происходит кража логинов, паролей и многофакторных кодов, причём система автоматически перехватывает подтверждающие СМС и подставляет цифры в нужные поля без участия человека. Группировка Mythic Likho (Arcane Werewolf) регистрировала целые кластеры поддельных доменов — от ilcloud[.]ru и cloudmaill[.]ru до gosuslugi-help[.]ru и dns-shop-client[.]ru, используя российского регистратора Рег.ру и скрывая IP управляющих серверов через Cloudflare. Фишинговая рассылка осуществлялась как раз с почтовых адресов этих доменных имён.

Примечательно, что атакующие маскировали свои домены под облачные хранилища, торговые сети и госуслуги — это указывает на целенаправленный выбор векторов, соответствующих интересам жертв из числа российских организаций.

На рисунке 1 представлены некоторые фишинговые домены, созданные в рамках данной вредоносной кампании.

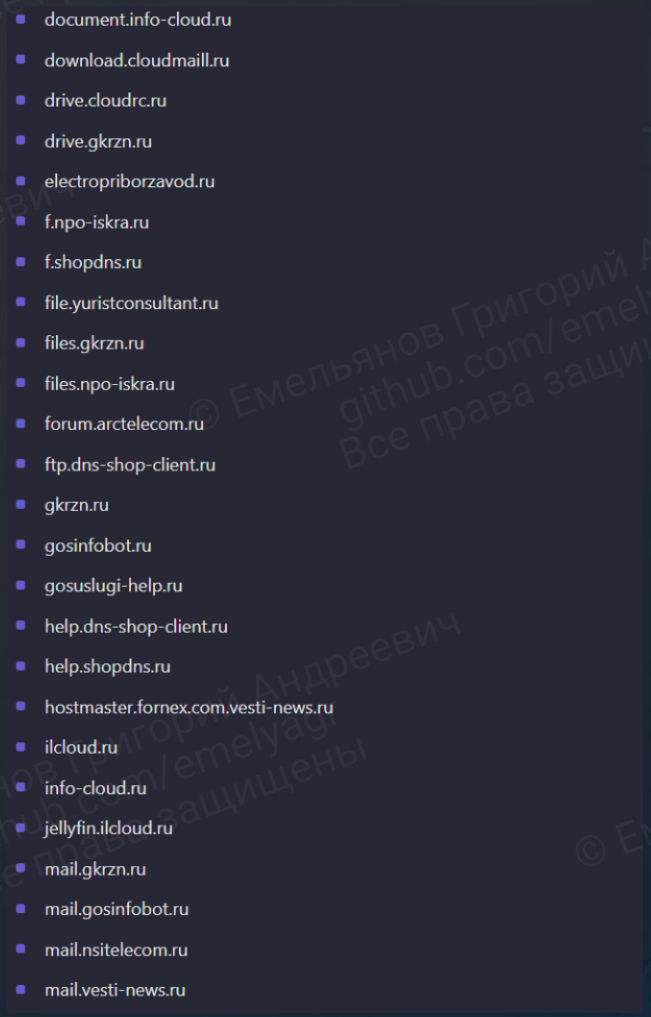


Рисунок 1 – Фишинговые домены

Финансовый сектор. Среди финансовых брендов мошенники чаще всего имитируют крупнейшие российские банки — «Сбер», «ВТБ», «Т-Банк» и «Альфа-банк». Характерный пример тайпсквоттинга — домен sberbank[.]id0718[.]com, где легитимное имя банка размещено в поддомене, что визуально создаёт иллюзию официального ресурса. Для аналитика важно:

банковские фишинговые домены часто используют поддоменную структуру, где бренд вынесен в третью зону, а основное доменное имя принадлежит ничего не подозревающему владельцу, но активная MX-запись на поддомене или основном домене может служить маркером подготовки к рассылке.

Совокупность признаков — свежая регистрация, наличие MX-записи, лексическое сходство с брендом, а также сезонная привязка к событию (коммерческие предложения, начало учебного года, отпускной сезон, отчётный период) — даёт аналитику достаточные основания для упреждающих действий. Российская инфраструктура противодействия позволяет направить такой домен на блокировку через НКЦКИ или сервис «Доменный патруль», при этом основная масса обращений обрабатывается регистраторами в первые часы.

Прогнозирование на основе анализа бюллетеней угроз ИБ

Метод опирается на систематический анализ бюллетеней CERT и баз данных угроз для построения профилей группировок — их TTP, целевых отраслей, географии и сезонности — с последующим сопоставлением с профилем защищаемой организации для прогнозирования атак.

В российском контексте фундаментальным источником является ФСТЭК России и НКЦКИ, рассылающие бюллетени субъектам КИИ, а также публикующие отчёты об угрозах и сведения об уязвимостях на своих сайтах. На рисунке 2 можно увидеть перечень актуальных угроза на сайте НКЦКИ.

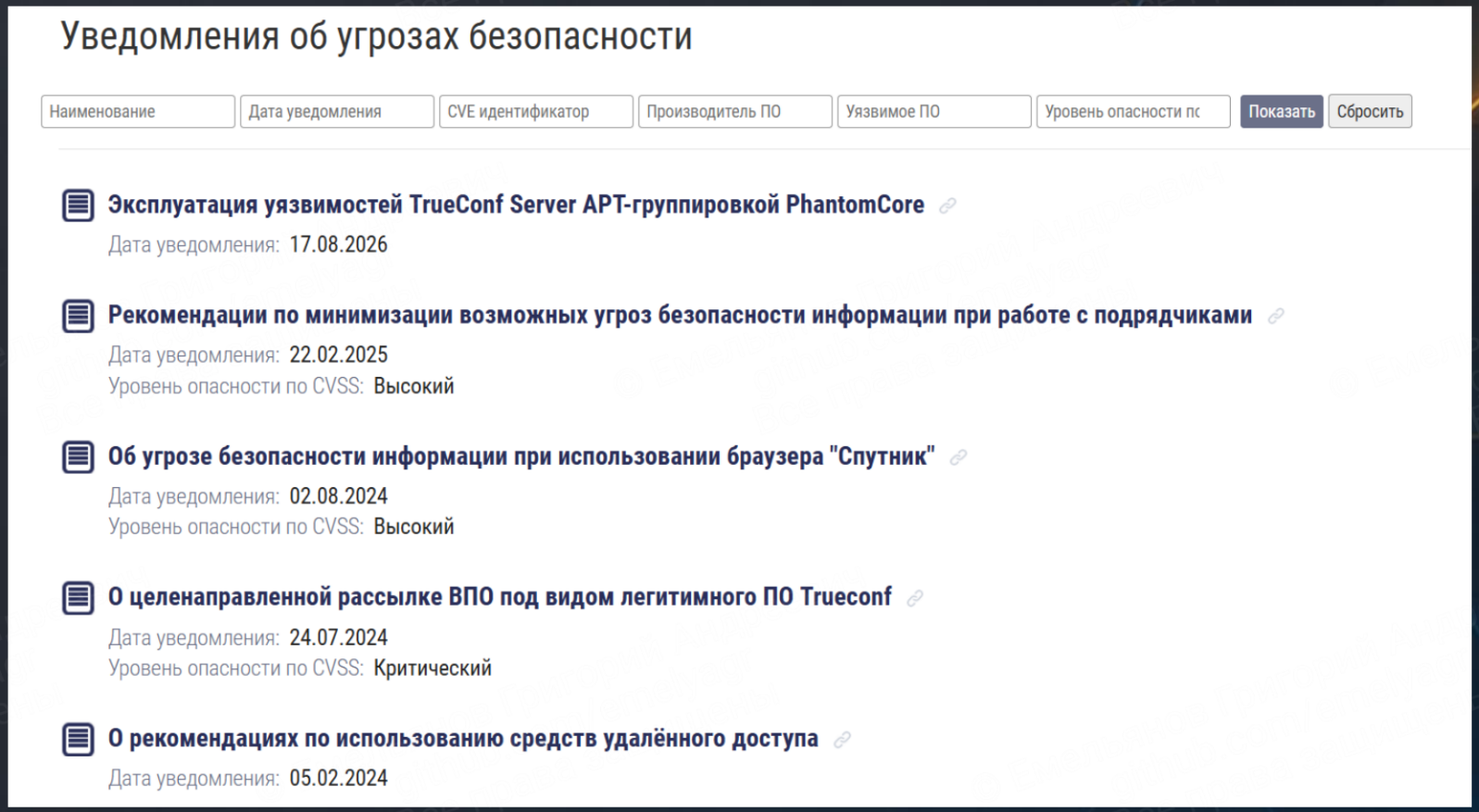


Рисунок 2 – Перечень актуальных угроз на сайте НКЦКИ

Методический документ «Методика оценки угроз безопасности информации», утверждённый ФСТЭК России 05.02.2021, предписывает использовать данные из БДУ на различных этапах моделирования угроз ИБ. При формировании общего перечня всевозможных киберугроз может применяться раздел «Новый раздел угроз», в котором формируется перечень актуальных угроз на основе входных данных. Для оценки угроз рекомендуется дополнительно использовать описания

векторов атак из методик регуляторов, фреймворки ATT&CK, CAPEC, CAR, CARET, OWASP, STIX или TI-решения.

На уровне оперативной координации НКЦКИ (Национальный координационный центр по компьютерным инцидентам) и ГосСОПКА решают задачу прогнозирования ситуации в области обеспечения информационной безопасности РФ. К одной из основных задач ГосСОПКА относится прогнозирование инцидентов в области обеспечения информационной безопасности РФ. Специалистами НКЦКИ могут оперативно предоставляться субъекту ГосСОПКА рекомендации по противодействию вредоносной активности. При этом НКЦКИ использует формализованное описание категорий компьютерных инцидентов и технических параметров каждого из них. Для финансового сектора аналогичную роль играет ФинЦЕРТ Банка России, рассылающий бюллетени с индикаторами компрометации участникам информационного обмена. Целесообразно подключить организацию к ГосСОПКЕ или ФинЦЕРТ, особенно при наличии объектов КИИ.

Отдельно стоит отметить, что ряд отечественных предприятий, предоставляющих услуги по информационной безопасности, получает данные об актуальных киберугрозах напрямую от ключевых российских регуляторов — НКЦКИ и ФСТЭК России, что позволяет пользователям быстрее узнавать о наиболее критичных угрозах, реагировать на них на ранних этапах и информировать уязвимые организации.

Практическая ценность профилирования хорошо видна на конкретных кампаниях. Ежегодно обнаруживаются десятки прогосударственных APT-групп, активно атакующих организации в России и СНГ, и их число устойчиво растёт. Анализ публичных отчётов подтверждает высокий

уровень давления на российские организации и устойчивый интерес злоумышленников к государственному и промышленному сегментам. Основной сценарий атак строится вокруг шпионажа и подрыва работы инфраструктуры, при этом противники всё чаще уходят от шумных техник и действуют скрытно и методично. В ряде кампаний злоумышленники комбинировали кражу данных с их последующим уничтожением, а в других — выстраивали долгосрочное присутствие, чтобы выкачивать документы и учётные данные.

Анализируя бюллетени угроз ИБ можно составлять профили активных группировок — её предпочитаемые TTP, целевые отрасли и возможности — и, сопоставив его с профилем конкретной организации, можно заранее подготовить специфичные контрмеры. Например, если организация работает в промышленном секторе, а профиль хакерской группировки указывает на использование фишинговых писем с LNK-файлами, — стоит усилить мониторинг именно этих техник: создание LNK-файлов, выполнение PowerShell-скриптов, установка легитимных агентов удалённого управления. Если профиль группировки указывает на частое использование поддоменных фишинговых схем, — стоит настроить дополнительные правила детекции для доменов, содержащих название вашего бренда, можно внедрить решения класса Threat Intelligence или Digital Risk Protection (DRP) или использовать услуги вендоров по информационной безопасности.

Прогнозирование на основе анализа открытых источников

OSINT-прогнозирование компьютерных атак может строиться разными способами:

- анализ агрегационных новостных ресурсов, содержащих информацию об актуальных атаках и угрозах из разных источников;

- анализ даркнет-ресурсов.

Систематический анализ новостных материалов формирует у аналитика устойчивую базу знаний о тактиках, техниках и процедурах (TTP) различных группировок. В результате накопления таких сведений специалист приобретает способность идентифицировать характерные признаки деятельности конкретных групп — предпочитаемые векторы атак, типовые легенды фишинговых кампаний, используемые семейства вредоносного ПО и методы закрепления. Это позволяет распознавать ранние индикаторы готовящихся атак даже при отсутствии формальных сигнатур или официальных отчётов, а также с высокой вероятностью атрибутировать инциденты.

Указанное понимание обеспечивает более широкий горизонт прогнозирования угроз и служит основой для выработки обоснованных рекомендаций для организаций-клиентов. Аналитик получает возможность оценить релевантность активности конкретной группировки для защищаемой инфраструктуры и предложить превентивные меры: усиление мониторинга определённых техник MITRE ATT&CK, проверку контрагентов на предмет компрометации, проведение целевых тренировок по фишингу. Таким образом, рекомендации приобретают прикладной характер и непосредственно привязываются к актуальному профилю угрозы, что повышает их практическую ценность для обеспечения безопасности организации.

Анализ даркнет-ресурсов для прогнозирования атак начинается с исследования обсуждений на форумах, публикациий эксплойтов, продажи доступов и координации действий. В российском

контексте это особенно актуально, поскольку значительная часть теневой активности сосредоточена именно в Telegram-каналах.

В связи с ужесточением контроля в Telegram и блокировкой ресурсов аналитики фиксируют две ключевые тенденции: обратную миграцию злоумышленников из мессенджеров на форумы в даркнете и дальнейший рост популярности моделей MaaS (Malware as a Service), RaaS (Ransomware as a Service), PhaaS (Phishing as a Service). Это означает, что аналитику необходимо одновременно мониторить оба канала — и Telegram, и специализированные форумы, поскольку атакующие осознанно распределяют свою инфраструктуру.

Практическая механика OSINT-мониторинга даркнета для прогнозирования инцидентов включает несколько ключевых направлений. В первую очередь это объявления о продаже доступов к российским организациям — анализ тысяч сообщений на форумах и в Telegram-каналах показывает, что значительная доля кластеров, нацеленных на российские компании, использует коммерческое вредоносное ПО, а стартовая цена взломанных корпоративных аккаунтов может быть символической — от 10 долларов.

Второе направление — мониторинг утечек баз данных и учётных данных. Аналитики изучают десятки форумов, отслеживая объявления о продаже утекших баз данных. Третье — отслеживание обсуждений конкретных CVE и публикации эксплойтов, что позволяет предсказать, какие уязвимости будут использоваться в ближайшее время. Четвёртое — выявление признаков подготовки атак: сканирование инфраструктуры, тестовые вторжения, регистрация фишинговых ресурсов под легитимные сервисы.

Платформы, анализирующие десятки тысяч сигналов в сутки из даркнета, Telegram, TI-фидов, OSINT и стилеров, позволяют анализировать угрозы для всей экосистемы клиента, после чего ML-модели выстраивают сценарии возможных атак с интерпретацией рисков для бизнеса — головной компании, дочерних структур, подрядчиков и поставщиков. Обычно данный функционал находится в решениях класса Threat Intelligence или Digital Risk Protection (DRP).

Также геополитические сигналы концентрируются в определённых точках и могут служить ранним индикатором. Для аналитика это означает, что мониторинг OSINT-упоминаний не только своей организации, но и её партнёров, поставщиков и даже отраслевых новостных сигналов позволяет предсказать атаку, которая технически может быть нанесена не по его инфраструктуре, а по доверенному контуру.

OSINT-разведка смещает защиту от реактивной модели, где SOC фиксирует уже состоявшийся инцидент, к проактивной, где сигналы об атаке формируются в открытом пространстве задолго до её технической реализации. Ключевые источники для мониторинга — Telegram-каналы хакерских группировок, форумы в даркнете и агрегаторы новостных ресурсов по ИБ. Важно отслеживать не только свою организацию, но и партнёров, поставщиков и отраслевые сигналы.

Заключение и прогнозы

Совокупность трёх методов — мониторинг новых тайпсквоттинговых доменных имён, OSINT-разведка, а также систематический анализ бюллетеней угроз с профилированием группировок — даёт аналитику комплексную систему упреждающего прогнозирования, где каждый метод усиливает остальные. Доменные сигналы дают раннее техническое предупреждение: свежая

регистрация плюс MX-запись плюс лексическое сходство с брендом — это сигнал с высоким приоритетом, который следует отрабатывать немедленно. OSINT-сигналы раскрывают намерения и контекст: обсуждения на форумах, продажа доступов, публикация эксплойтов формируют картину готовящейся атаки задолго до её технической реализации. Анализ бюллетеней обеспечивает понимание того, кто именно и зачем может атаковать: профиль группировки, сопоставленный с профилем организации, позволяет заранее подготовить специфичные контрмеры.

В российском контексте эти методы опираются на развитую инфраструктуру: проект «Доменный патруль» с компетентными организациями, Банк данных угроз ФСТЭК России, координация через НКЦКИ и ГосСОПКА, отраслевые бюллетени ФинЦЕРТ. Главная практическая ценность прогнозирования — не сам прогноз, а время на реакцию. Даже прогноз с небольшим горизонтом — за несколько часов до рассылки или за день до атаки — даёт команде ИБ небольшое время, чтобы заблокировать домен, усилить мониторинг или применить правила межсетевого экранирования до начала атаки.